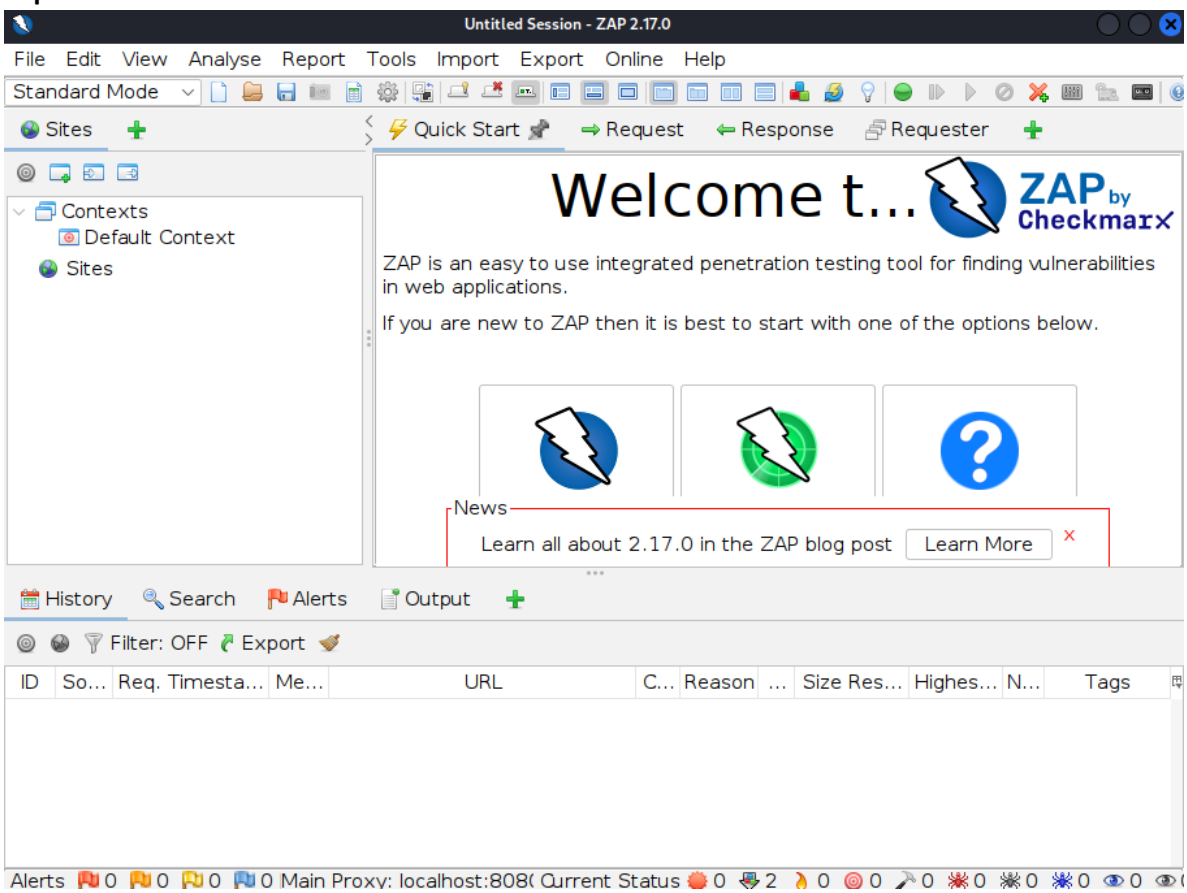


Nombre: Nelly Guadalupe Lara Hernández

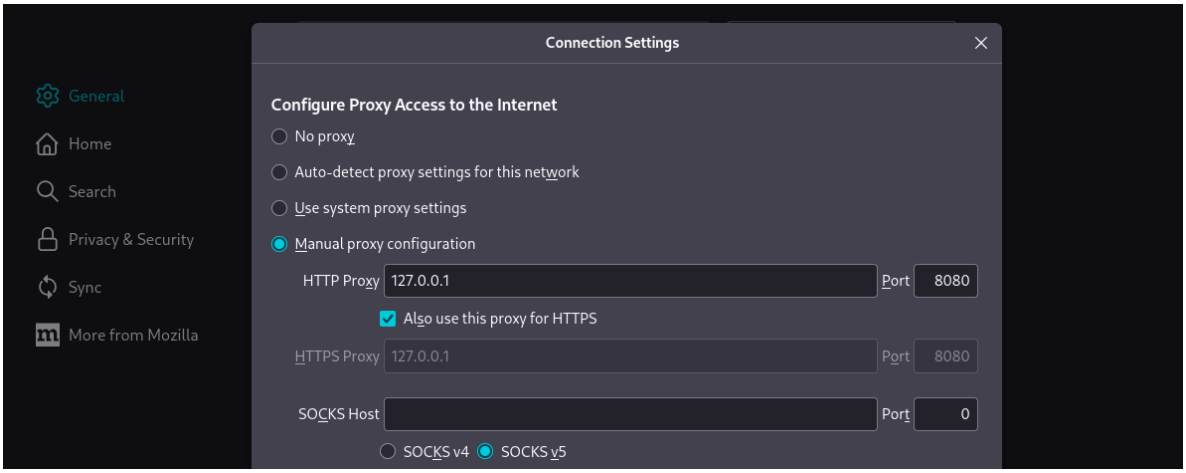
Evaluación de seguridad web Gin & Juice Shop

1. Prepara el entorno

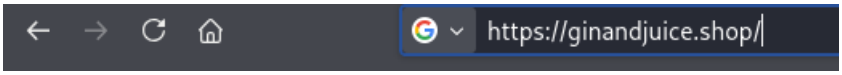
1.1 Zap abierto

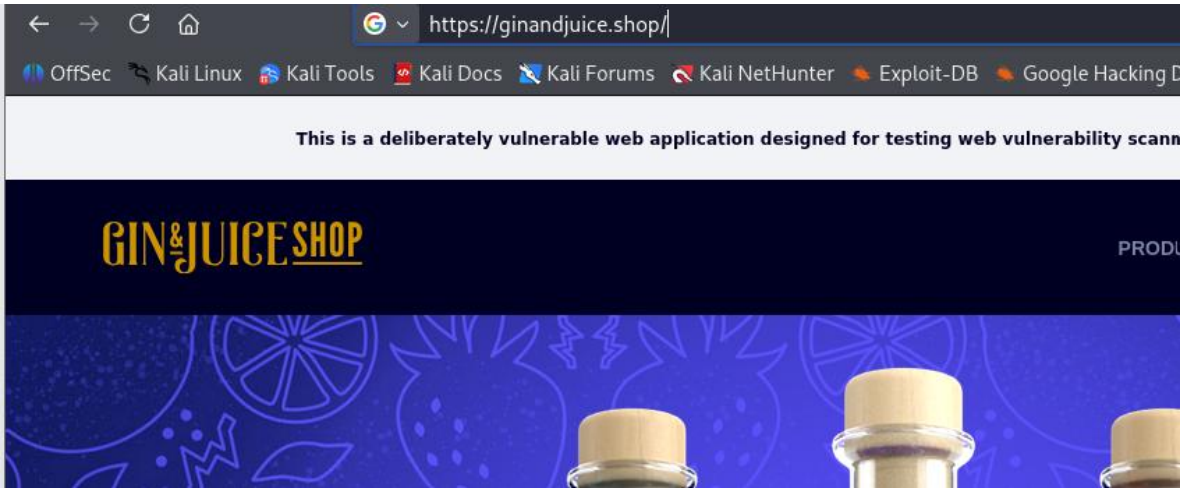


1.2 Navegador configurado

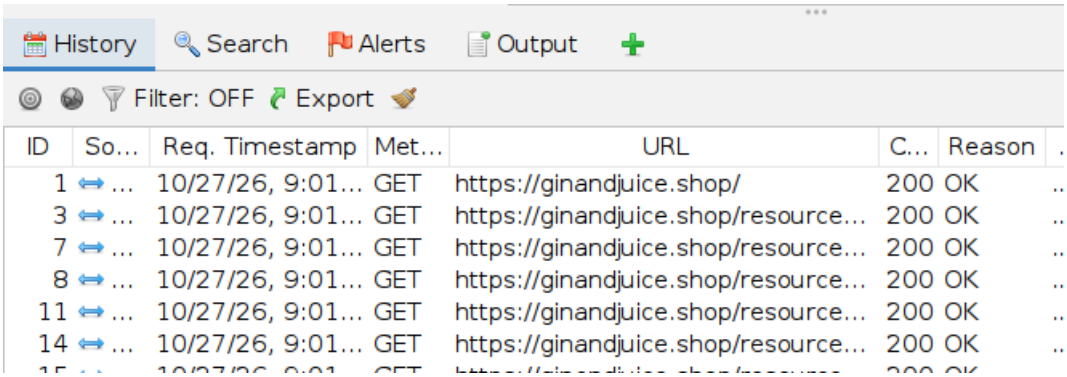


1.3 Acceso a https://ginandjuice.shop/



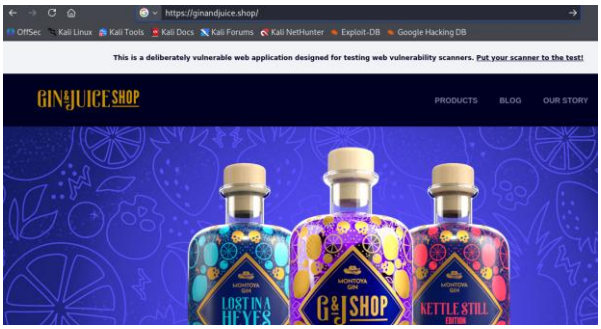


1.4 Verificación de que el tráfico aparece en Zap

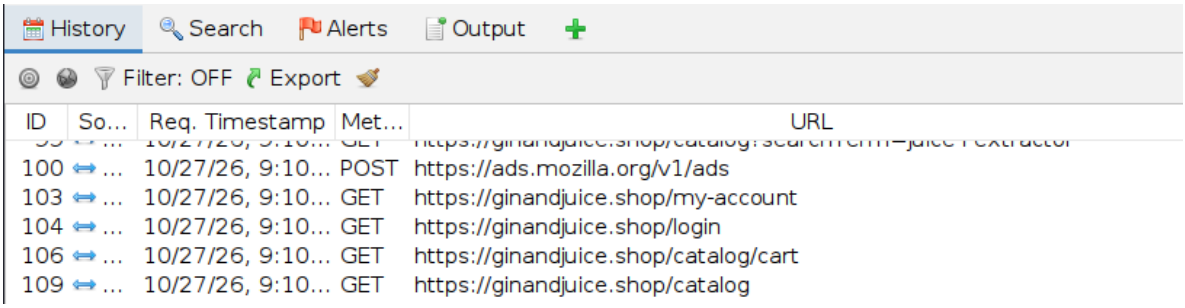


2.Explora la aplicación

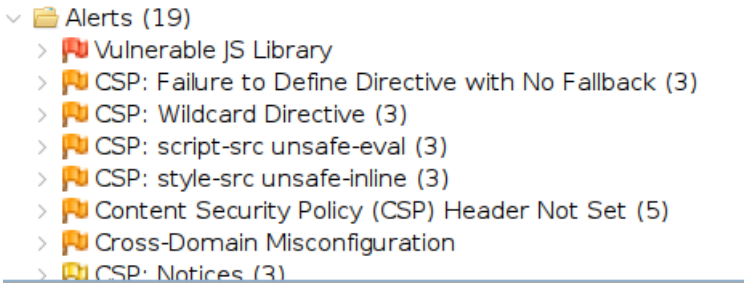
2.1 Navegación en el sitio



2.2 Tráfico HTTP en ZAP



3. Analiza las alertas



X-Content-Type

Nivel: Bajo

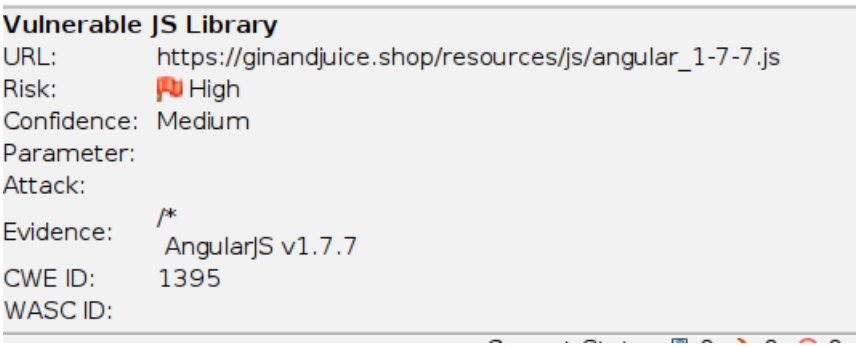
Vulnerable JS Library

Nivel: Alto

Strict-Transport-Security

Nivel: Bajo

4. Documenta un hallazgo principal



Ficha técnica

1.	**Nombre de la alerta**	Vulnerable JS Library
2.	**Nivel de riesgo**	Alto
3.	**URL o componente**	https://ginandjuice.shop/resources/js/angular_1-7-7.js
4.	**Parámetro afectado**	-
5.	**Evidencia**	/* AngularJS v1.7.7
6.	**Descripción técnica**	The identified library appears to be vulnerable.
7.	**Impacto potencial**	Ejecución de código malicioso en el navegador de los usuarios (Cross-Site Scripting / XSS y Template Injection), lo que permite a un atacante robar cookies de sesión, credenciales o tokens de autenticación, suplantar la identidad de usuarios legítimos, manipular el contenido visible de la aplicación y redirigir el tráfico hacia sitios maliciosos.
8.	**Recomendación**	Actualiza a la versión más reciente de la biblioteca afectada.

5. Conclusiones

- **¿Qué aprendí?**

Aprendí a utilizar OWASP ZAP como un proxy de interceptación y análisis de seguridad pasivo y activo. La herramienta me proporcionó visibilidad total del tráfico HTTP/HTTPS entre el cliente y el servidor, mapeando las peticiones realizadas a `ginandjuice.shop`. A través de su motor de análisis, me permitió identificar de manera automática debilidades arquitectónicas y de configuración, destacando la presencia de componentes desactualizados como **Vulnerable JS Library (AngularJS v1.7.7)** y múltiples carencias en las políticas de seguridad de cabeceras (**CSP**, **HSTS** y **X-Content-Type**).

- **¿Qué fue lo más retador?**

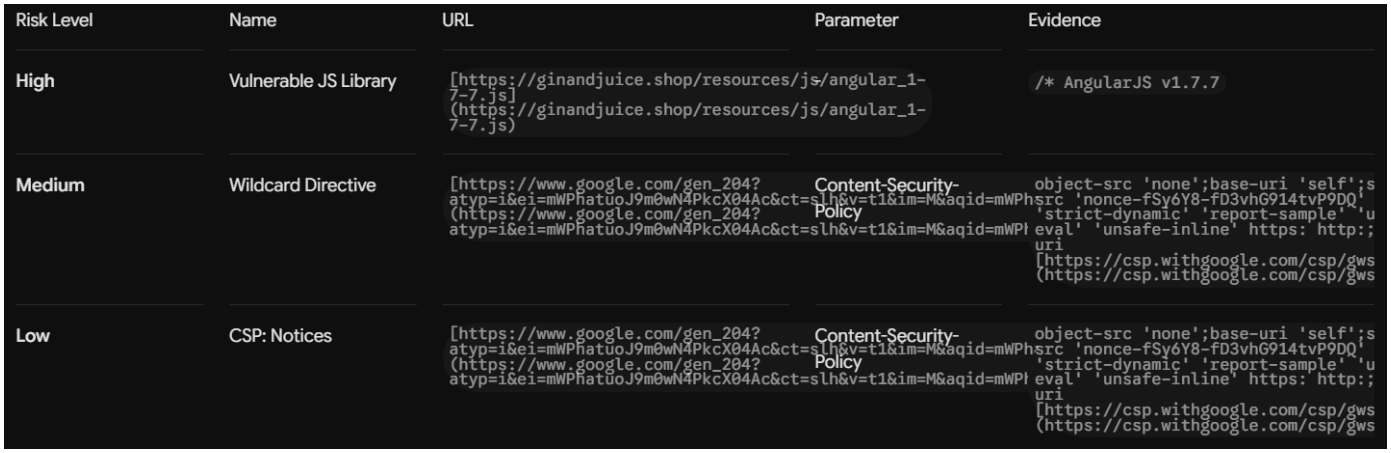
El principal reto técnico fue el enlace inicial del entorno: configurar correctamente el proxy manual en Firefox (`127.0.0.1:8080`) y la gestión del certificado raíz SSL/TLS de ZAP. Al principio, el navegador bloquea las conexiones HTTPS por alertas de seguridad (Man-in-the-Middle); esto se resolvió exportando la entidad certificadora raíz desde ZAP e importándola en el almacén de certificados de Firefox con permisos de confianza para sitios web.

- **¿Qué revisaría a continuación?**

En un entorno real o auditoría completa, realizaría:

1. **Active Scanning y Fuzzing focalizado:** Enviar payloads controlados sobre los parámetros de entrada de formularios (búsqueda, login, checkout) para detectar inyecciones SQL (SQLi) o Cross-Site Scripting (XSS) reflejado/almacenado.
2. **Análisis de autenticación y sesiones:** Validar la robustez de las cookies de sesión (atributos `Secure`, `HttpOnly`, `SameSite`), expiración de tokens JWT y control de acceso a nivel de endpoints administrativos o perfiles de usuario.

3. **Verificación de dependencias (SCA):** Probar si la versión obsoleta de AngularJS permite evasión de sandbox (Sandbox Escape) o Template Injection del lado del cliente para ejecutar scripts arbitrarios.



Risk Level	Name	URL	Parameter	Evidence
High	Vulnerable JS Library	[https://ginandjuice.shop/resources/js/angular_1-7-7.js] (https://ginandjuice.shop/resources/js/angular_1-7-7.js)		/* AngularJS v1.7.7
Medium	Wildcard Directive	[https://www.google.com/gen_204?atyp=i&ei=mWPhatuoJ9m0wN4PkcX04Ac&ct=slh&v=t1&im=M&aqid=mWPh (https://www.google.com/gen_204?atyp=i&ei=mWPhatuoJ9m0wN4PkcX04Ac&ct=slh&v=t1&im=M&aqid=mWPh	Content-Security-Policy	object-src 'none';base-uri 'self';src 'nonce-fSy6Y8-fD3vhG914tvP9DQ' 'strict-dynamic' 'report-sample' 'eval' 'unsafe-inline' https: http:;uri [https://csp.withgoogle.com/csp/gws (https://csp.withgoogle.com/csp/gws
Low	CSP: Notices	[https://www.google.com/gen_204?atyp=i&ei=mWPhatuoJ9m0wN4PkcX04Ac&ct=slh&v=t1&im=M&aqid=mWPh (https://www.google.com/gen_204?atyp=i&ei=mWPhatuoJ9m0wN4PkcX04Ac&ct=slh&v=t1&im=M&aqid=mWPh	Content-Security-Policy	object-src 'none';base-uri 'self';src 'nonce-fSy6Y8-fD3vhG914tvP9DQ' 'strict-dynamic' 'report-sample' 'eval' 'unsafe-inline' https: http:;uri [https://csp.withgoogle.com/csp/gws (https://csp.withgoogle.com/csp/gws